Missing Content-Security-Policy Header – Absence of Browser-Level XSS Prevention

Severity: Medium

CVSS Score: 5.5 (Medium)

(This can drop to low severity, if the other XSS vulnerabilities are mitigated)

CWE

- **CWE-693**: Protection Mechanism Failure
- **CWE-1021**: Improper Restriction of Rendered UI Layers or Frames (related)

Affected Asset

- **URL**: https://crm-stage.crusource.com
- **Parameter/Storage Key**: HTTP Response Header
- **Environment**: Staging
- **Date Discovered**: 11-10-2026

Why this is a vulnerability:

- The CRM application does not return a 'Content-Security-Policy' (CSP) header in its HTTP responses. CSP is a browser-enforced security mechanism that restricts which sources of executable content (scripts, styles, frames, etc.) are permitted to load on a page. Its primary purpose is to mitigate Cross-Site Scripting (XSS) and related client-side injection attacks.

- When CSP is absent, the browser applies no restrictions on script execution. Any injected script – whether through a stored, reflected, or DOM-based XSS vulnerability - will execute without browser-level interference. This removes a critical defense-in-depth layer that would otherwise contain or block exploitation attempts.

Delivery vector (how an attacker would steal it):

- **No Script Execution Restrictions:** Injected scripts execute without browser-level blocking or sandboxing.
- **Session Token Theft:** If XSS is present, an attacker can read 'localStorage' (where authentication tokens are stored) and exfiltrate them.
- **Data Exfiltration:** Malicious scripts can send sensitive CRM data (customer PII, internal notes, credentials) to attacker controlled servers.
- **Account Takeover:** Combined with the existing token storage weakness, missing CSP enables full session hijacking.
- **Third-Party Script Compromise:** A compromised analytics, chat, or advertising script would execute without restriction.

Remediation recommendation:

1. Configure the CRM web server or application framework to emit a restrictive Content-Security-Policy header on all responses.
2. Replace {random} with a cryptographically random nonce generated per-response and applied to legitimate inline scripts.
3. frame-ancestors 'none' also mitigates clickjacking, replacing the need for X-Frame-Options.
4. object-src 'none' prevents legacy plugin-based attacks.
5. base-uri 'self' prevents base tag hijacking.
6. Test the policy in **Report-Only** mode first (Content-Security-Policy-Report-Only) to identify legitimate resources that would be blocked before enforcing it.

Summary

The CRM application at https://crm-stage.crusource.com does not return a CSP header in its HTTP responses. While not directly exploitable on its own, the missing CSP significantly amplifies the impact of any XSS vulnerability, it still removes a critical browser-level defense against Cross-Site Scripting (XSS) and content injection attacks. Thus enabling unrestricted script execution, session token theft, data exfiltration, and potential account takeover. Remediation requires implementing a restrictive CSP policy on all responses.